CYBERSECURITY INTERNSHIP

Technical Documentation

Weeks 5

Week 4: Advanced Threat Detection & Web Security
Week 5: Ethical Hacking & Vulnerability Exploitation
Week 6: Advanced Security Audits & Secure Deployment

Deadline: 27th March 2026

WEEK 5: Ethical Hacking & Exploiting Vulnerabilities

Goal
Learn ethical hacking techniques, exploit vulnerabilities in a test environment, and enhance application security.

Task 1 – Ethical Hacking Basics

Kali Linux Setup (VirtualBox mein)

- VirtualBox download: virtualbox.org (FREE)
- Kali Linux .ova file download: kali.org/get-kali → VirtualBox image
- VirtualBox in File > Import Appliance se .ova import
- Default login: Username: kali | Password: kali

Reconnaissance (Information Gathering)

```
# Nmap se target scan karo
nmap -sV -sC testphp.vulnweb.com

# Open ports aur services dekhne ke liye
nmap -p 80,443,8080 testphp.vulnweb.com

# Nikto web scanner
nikto -h http://testphp.vulnweb.com
```

Burp Suite Setup

- Burp Suite Community Edition download: portswigger.net/burp/communitydownload
- Firefox in proxy set karo: 127.0.0.1:8080
- Intercept tab ON karo aur traffic capture karo

Task 2 – SQL Injection & Exploitation

SQLMap se SQL Injection Dhundo

```
# Basic SQL injection test
sqlmap -u 'http://testphp.vulnweb.com/artists.php?artist=1' --dbs

# Tables list karo
sqlmap -u 'http://testphp.vulnweb.com/artists.php?artist=1' -D acuart --tables

# Data dump karo
sqlmap -u 'http://testphp.vulnweb.com/artists.php?artist=1' -D acuart -T users --dump
```

SQL Injection Fix — Prepared Statements

GALAT tareeqa (Vulnerable Code):

```
// GALAT — SQL Injection possible hai
const query = `SELECT * FROM users WHERE id = ${userId}`;
db.query(query);
```

SAHI tareeqa (Secure Code):

```
// SAHI — Prepared Statement use karo
const query = 'SELECT * FROM users WHERE id = ?';
db.execute(query, [userId], (err, results) => {
  if (err) return res.status(500).json({ error: 'DB Error' });
  res.json(results);
});
```

Task 3 – CSRF Protection

CSRF kya hai?

Cross-Site Request Forgery (CSRF) is an attack in which attacker on behalf of your logged-in user sends a request. For example: user bank site par logged in hai, and the attacker ek through a hidden form transfers money.

csurf Middleware Installation

```
npm install csurf cookie-parser
```

Implementation

```
const csrf = require('csurf');
const cookieParser = require('cookie-parser');

app.use(cookieParser());
app.use(csrf({ cookie: true }));

// CSRF token frontend ko do
app.get('/form', (req, res) => {
  res.json({ csrfToken: req.csrfToken() });
});

// Frontend form mein hidden field add karo
<input type='hidden' name='_csrf' value='{{csrfToken}}'>
```

CSRF Test with Burp Suite

- Burp Suite open
- Form submit intercept karo
- _csrf token remove
- Request forward — server 403 Forbidden dega (CSRF working)

Week 5 Deliverables Checklist

✅ Kali Linux setup in VirtualBox ✅ Nmap + Nikto reconnaissance report ✅ SQLMap scan results (on test site only) ✅ Prepared statements implemented in backend ✅ CSRF protection with csurf middleware ✅ Ethical hacking report written ✅ GitHub updated with security fixes

Week 5: Ethical Hacking Report Template

Item	Details
Target	testphp.vulnweb.com (test environment)
Scope	Web application only
Tools Used	Nmap, Nikto, SQLMap, Burp Suite
SQL Injection	Found in ?artist= parameter — Fixed with prepared statements
CSRF	POST /transfer endpoint vulnerable — Fixed with csurf token
Open Ports	80 (HTTP), 443 (HTTPS)